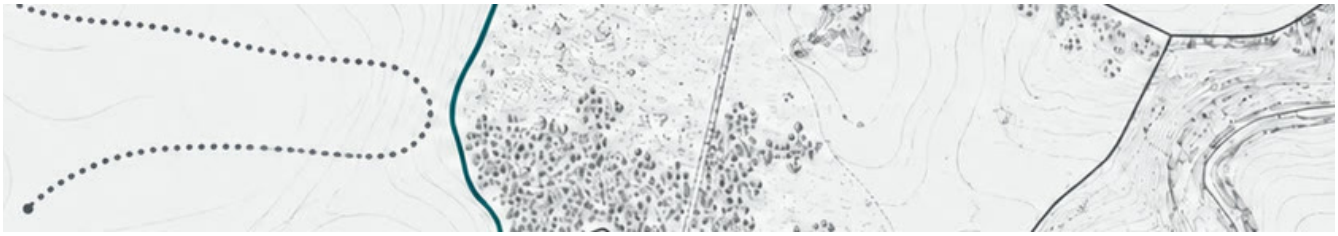
Identity governance voor AI-agents



Joiner-mover-leaver, recertificering en eigenaarschap voor een AI-agent bij de overheid.

Michael Owen Meijer, Oomny B.V. · identity-architect en AI-engineer voor overheid en cloud

Het probleem

Wie is eigenaar van deze agent, mag hij nog bestaan, en wat gebeurt er als die eigenaar vertrekt of van team wisselt? Voor medewerkers regelt identity governance (IGA) dat met joiner-mover-leaver en recertificering. Een serviceaccount of API-sleutel regelt dat op zichzelf niet voor een agent. Zonder eigenaar en vervaldatum blijft zijn toegang staan, ook als niemand er nog verantwoordelijk voor is.

De aanpak

Een agent doorloopt hetzelfde governanceproces als een medewerker:

- **Joiner.** De beheerder provisioneert de agent via SCIM 2.0 met een menselijke eigenaar, een doel, een vervaldatum en een risicoklasse. Tot de eigenaar hem bevestigt, doet de agent niets.
- **Mover.** De agent erft zijn toegang van de teams van zijn eigenaar (agent → eigenaar → team → dossier in OpenFGA). Wisselt de eigenaar van team, dan wordt de agent geweigerd tot een nieuwe bevestiging en volgt zijn toegang daarna het nieuwe team. Niemand zet per agent iets om.
- **Leaver.** Vertrekt de eigenaar, dan wordt de agent gedeactiveerd en bij zijn volgende toolcall geweigerd, ook midden in een opdracht. Registratie en auditspoor blijven bewaard.
- **Recertificering met een harde termijn.** De eigenaar bevestigt de agent periodiek. Blijft dat uit of is de vervaldatum bereikt, dan weigert de poort hem. Na de vervaldatum weigert OpenFGA ook zelf.
- **Eén logboek.** Levenscyclusgebeurtenissen en toolcalls staan in één hashketen met een anker op een apart volume. Een gewijzigd record of een weggelaten staart valt op.

Het bewijs

Een publieke repo met een werkende demo in één commando (`make demo`), zonder API-sleutels. Een LangGraph-agent werkt via een MCP-gateway op dossiers van een fictieve gemeente. Vijf scenario's: joiner, prompt-injectie, mover, leaver midden in een opdracht en verlopen zonder herbeoordeling. Een ingevoegde instructie in een dossierbijlage stuurt de agent naar een dossier van een ander team. Dat strandt op de ontbrekende relatie, niet op het oordeel van het model. De demo eindigt met de bewijstabel uit het logboek, een controle van keten en anker, en een manipulatieproef.

236 unittests, 36 integratietests tegen de echte keten en modeltests voor OpenFGA. Een dreigingsmodel tegen de OWASP Top 10 for Agentic Applications 2026 en de OWASP Non-Human Identities Top 10, met per risico de test die het bewijst. Een eerlijke paragraaf over wat dit niet oplost.

Waarom van mij

Identity en security sinds 2011, bijna acht jaar voor de vier grote gemeenten: identiteitensynchronisatie met MIM, SCIM-provisioning vanuit de gemeenten, PIM met access reviews in Entra ID, en de inrichting van Keycloak (cutover in voorbereiding). Sinds 2026 bouw ik AI-agents met tool calling en MCP. Voor medewerkers is dit governanceproces al jaren gewoon; voor agents begint het nu.

Repo: github.com/oomny-nl/agent-levenscyclus · **Site:** www.oomny.nl · **Mail:** michael@oomny.nl